Actividad 19 — Construcción de una línea base de seguridad para PostgreSQL 16

1. Red

- Interfaces autorizadas: configurar listen_addresses para escuchar únicamente en las interfaces necesarias. Si PostgreSQL solo se utiliza desde el mismo equipo, establecer localhost. Si necesita conexiones remotas, autorizar únicamente la interfaz de red correspondiente.
- Puerto: mantener el puerto predeterminado 5432, salvo que exista una justificación técnica para cambiarlo. Cambiar el puerto por sí solo no constituye una medida de seguridad suficiente.
- Firewall: crear reglas de entrada que permitan conexiones únicamente desde equipos o servidores autorizados. Bloquear las conexiones entrantes que no sean necesarias.
- Redes permitidas: limitar el acceso a direcciones IP específicas o a subredes de confianza. Evitar exponer PostgreSQL directamente a Internet.

2. Autenticación

- Método: utilizar scram-sha-256 como método de autenticación para las conexiones que lo admitan.
- Políticas de credenciales: exigir contraseñas largas, únicas y difíciles de adivinar. Evitar compartir credenciales y cambiarlas cuando exista sospecha de exposición o cuando la política institucional lo requiera.
- Cuentas administrativas: reservar la cuenta postgres para tareas administrativas justificadas. No utilizarla para las actividades cotidianas de las aplicaciones.
- Archivo pg_hba.conf: revisar las reglas de acceso y mantener únicamente las necesarias. Evitar reglas generales que permitan conexiones desde cualquier dirección.

3. Autorización

- Roles: definir roles según las funciones de cada usuario, separando administración, análisis y soporte.
- Privilegios: aplicar el principio de mínimo privilegio. Otorgar únicamente permisos necesarios sobre las bases de datos, esquemas, tablas y vistas correspondientes.
- Cuentas de aplicación: utilizar cuentas individuales para las aplicaciones, con permisos limitados a sus operaciones. Evitar que las aplicaciones se conecten con la cuenta postgres.
- Roles de grupo: utilizar roles sin inicio de sesión cuando resulte apropiado para agrupar privilegios y asignarlos a usuarios autorizados.
- Revisión de permisos: comprobar periódicamente los privilegios y retirar aquellos que ya no sean necesarios.

4. Configuración

- Parámetros relevantes: establecer listen_addresses según las interfaces autorizadas, password_encryption = 'scram-sha-256', ssl = on cuando el certificado esté configurado correctamente y ssl_min_protocol_version = 'TLSv1.2'.
- Extensiones: conservar únicamente las extensiones necesarias y autorizadas. En el entorno revisado se encontraron pgcrypto y plpgsql; deben mantenerse si las funciones del laboratorio o de la aplicación las requieren.
- Conexiones: conservar max_connections = 100 como valor inicial, revisando el consumo real antes de modificarlo. Establecer límites de conexiones por rol cuando sea necesario.

- Registro de actividad: habilitar registros adecuados para detectar errores de autenticación y actividad administrativa sospechosa, cuidando que los registros no expongan contraseñas ni información sensible.

5. Sistema operativo

- Propietario de archivos: los archivos de PostgreSQL deben pertenecer a la cuenta de servicio responsable de ejecutar el servidor, con permisos administrativos controlados.
- Permisos: limitar la lectura, escritura y modificación de los archivos de configuración, certificados, claves privadas y copias de seguridad a las cuentas autorizadas.
- Protección del directorio de datos: restringir el acceso a E:\postgre\data, evitando que usuarios no autorizados puedan consultar o modificar archivos de la base de datos.
- Administración del sistema: utilizar cuentas administrativas de Windows solo cuando sea necesario y mantener actualizado el sistema operativo.

6. Cifrado

- TLS: configurar TLS para cifrar las conexiones de red. Antes de habilitarlo, verificar que existan un certificado válido y una clave privada protegida. PostgreSQL requiere esos archivos para iniciar con SSL/TLS habilitado.
  PostgreSQL
- Verificación de conexiones: comprobar desde PostgreSQL que las conexiones utilizan cifrado mediante pg_stat_ssl. Para conexiones remotas, configurar el cliente para validar el certificado del servidor.
- Protección de credenciales: utilizar scram-sha-256, evitar guardar contraseñas en texto claro en archivos SQL o repositorios y no compartir credenciales entre usuarios.
- Información sensible: restringir los permisos sobre datos personales, aplicar minimización y enmascaramiento cuando corresponda, y utilizar pgcrypto únicamente cuando exista una necesidad de cifrado a nivel de datos.

7. Mantenimiento

- Actualización: instalar las actualizaciones de seguridad de PostgreSQL 16 y del sistema operativo después de evaluar su compatibilidad y realizar respaldos.
- Revisión periódica: revisar mensualmente los roles, privilegios, conexiones, reglas de acceso, registros y configuración de seguridad; ajustar la frecuencia según el riesgo.
- Copias de seguridad: realizar respaldos periódicos, protegerlos con permisos y cifrado apropiados y probar su restauración.
- Documentación: registrar la configuración aprobada, las modificaciones realizadas, la fecha, el responsable y los resultados de las pruebas.
- Verificación: comparar la configuración real con la línea base después de cada cambio importante y corregir las desviaciones detectadas.